

資安溝通力

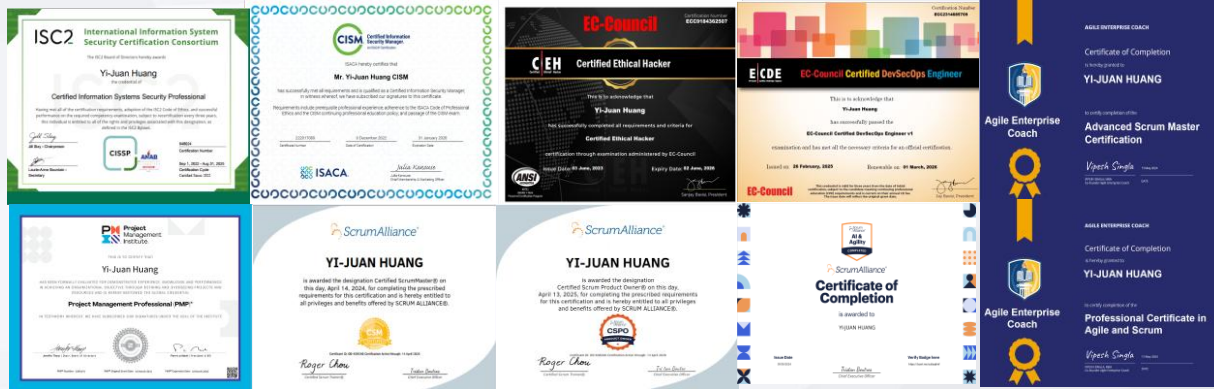
把技術風險翻譯成老闆聽得懂的話

*Cybersecurity Communication:
Translating Technical Risks into Business Decisions*

Presenter : 黃一展 (Nicky)
PMP/CSPO/CSM/CISSP/CISM/CEH



- ISC2 台北分會選委會主委(2024/2026)
- InfoSec 2023,2024 Speaker
- 2023年PMI-TW專案管理大獎(PTGA)傑出專案領袖獎
- 台灣敏捷社群 DevSecOps Taiwan Agile Leader
- RSG TAIPEI 2024 活動組 Scrum Master
- 近年來透過志願活動推廣資安、敏捷與專案管理知識



你的風險報告，老闆看完了嗎？

2025 年，台灣一家金融機構因內部權限管控疏失，數十萬名客戶資料外洩。事後調查揭露：資安團隊早在三個月前就已提出風險評估報告。報告送出去了，但沒有人做出對應的決策。

⚠️ 今天要談的，不是技術本身——
而是那份報告到底出了什麼問題，以及我們可以怎麼修正它。

同一件事，兩個世界

技術人與決策者之間，說的根本不是同一種語言。

工程師說

CVSS 9.8，建議立即修補

攻擊面擴大，橫向移動風險高

已提交修補 ticket，等待排程

零時差漏洞，需緊急應變

老闆聽到的

工程師又在說聽不懂的東西

大概是 IT 問題，讓他們處理

有人在處理，我不用管

「零時差」是什麼意思？

 Bitdefender 2025：45% 的 C-level 主管表示對資安「非常有信心」，但信心的根據往往不是真正理解技術風險，而是「有人在處理」的感覺。
C-Suite 與基層團隊之間存在顯著資安認知落差。

大企業

CISO 送報告 → 董事會「聽完」→ 沒有決策 (IANS 2026：95% 定期報告，只有 30% 真正合作)

中小企業

技術人說「有漏洞」→ 老闆說「這樣嚴重嗎？你們 IT 處理一下」

問題不是技術不夠嚴重 是沒有人在做翻譯

263萬

每日攻擊次數

台灣每天遭受的網路攻擊次數，問題不是「會不會被打」，而是「被打了有沒有人知道」。

58%

CISO 溝通困難

FTI Consulting：超過一半的資安長表示，難以將技術語言翻譯成高層主管能理解的方式。

30%

真正合作比例

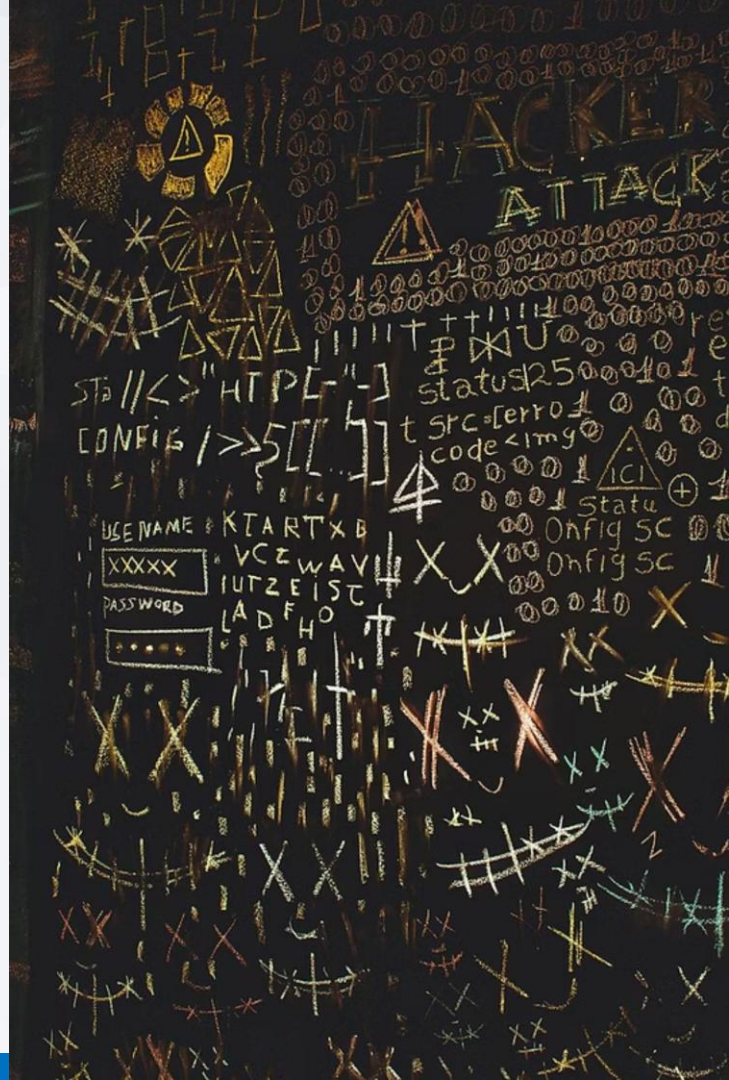
IANA 2026 報告：95% 的 CISO 定期向董事會報告，但只有 30% 的董事會會做決定。其餘 70% 只是在聽報告，沒有真正的決策。

大企業

Gartner 2025：溝通風險連續多年是 CISO 首要挑戰，不是技術，是語言。

中小企業

Devolutions 2025：71% 有信心，只有 22% 真正達到進階資安水位——老闆的信心可能來自不了解真正的風險。



技術語言 vs 決策語言

決策語言有三個特點：有具體行為主體、有時間感、有業務連結。這三個特點，是翻譯成功的關鍵。

技術語言 (工程師的框架)	決策語言 (老闆的框架)
CVE-2025-XXXX · CVSS 9.8	駭客不需密碼就能進系統，今天就能做到
權限提升，影響 Domain Admin	攻擊者可拿到所有員工帳號，含財務系統
橫向移動，攻擊鏈完整	一個入口點就能癱瘓整個內網
建議修補時程 14 天	14 天內不處理，等同開著後門營業
誤判率 3%，偵測率 94%	每 100 次攻擊會漏 6 次，但那 6 次可能最嚴重

- 📌 **CompTIA 2025** | 主管普遍低估資安障礙，與 IT 人員的認知差距顯著。主管不是不在乎，他只是用不同的框架在看同一件事。你的工作，是把你的框架翻譯成他的框架。

溝通失敗，不是技術失敗

✗ 分析師順序（技術人的習慣）

→ 問題

描述發現了什麼技術漏洞

→ 原因

分析攻擊向量與成因

→ 數據

堆疊技術指標與 CVE 資料

→ 結論

最後才給出建議（老闆已關掉）

✓ 決策者順序（老闆需要的）

→ 結論

開場直接說風險等級與建議

→ 影響

業務損失、法規裁罰、聲譽衝擊

→ 選項

三個可行方案，各有成本與代價

→ 建議

明確說出你推薦哪個，原因是什麼

「衡量與溝通風險，連續多年是 CISO 的首要挑戰。」—— Gartner 《2025 CISO Leadership Perspective Survey》

「95% 的 CISO 定期向董事會報告，但大多數互動僅限於聆聽與接收，未深入討論威脅與業務影響。」—— IANS/Artico Search 《2026 Benchmark Report》

技術能力不是瓶頸，翻譯能力才是。

TECH → BUSINESS 五步翻譯模型

「有效的 CISO，把網路威脅框架為業務風險，而非純技術問題。以業務連續性、聲譽與財務影響來情境化資安事件，讓 CEO 和董事會能將資安視為更廣泛風險景觀的一部分。」—— WEF 《2025 全球資安展望報告》

1 定受眾
你在跟誰說話？先確認決策者的角色與關注點

2 換單位
技術指標換成金額 (NT\$) 和時數

3 綁法規
把外部合規壓力帶進來，讓要求有強制力

4 給選擇
不只報問題，給老闆三個可選方案

5 說時間軸
讓人知道不動的代價會隨時間放大

今天結束前，你會拿到每一步的實戰工具。

Step 1：定受眾——同一個漏洞，對三個人說三種話

CISO

- 攻擊向量 / 修補方案
- CVE 評分 / 架構影響

開口第一句：「這個漏洞 CVSS 9.8，修補方案是...」

CFO

- 損失金額 / 修補成本
- 投資回報 / 金管會罰則

開口第一句：「預估損失 NT\$300 萬，修補 NT\$20 萬」

CEO

- 營運中斷 / 品牌聲譽
- 監理壓力 / 今天的決定

開口第一句：「這件事一旦爆，會上新聞」

 WEF 2025 | 60% 的 CEO 與 CISO 表示資安已整合進企業整體風險管理，但不到一半認為組織投入足夠。每個人對「重要」的定義不同——你的工作是說那個人在乎的事。

大企業

三個角色、三種說法——進場前標出主要受眾，對準他最在乎的維度。

中小企業

老闆只有一個，三種擔心：公司會不會倒、客戶會不會跑、這週能不能搞定。

Step 2：換單位——「嚴重」不是單位，NT\$300 萬才是

✗ Before

「此漏洞 CVSS 評分 9.8，屬 Critical 等級，建議立即修補以降低資安風險。」

CEO反應：不知道要做出什麼決定。

✓ After

「這個漏洞如果被利用，系統停機 4–8 小時，以每小時平均營業額估算，損失在 NT\$150–300 萬之間。另有金管會裁罰風險。修補費用 NT\$20 萬，本月可完成。」

CEO反應：知道他面對什麼選擇。

📄 IBM 2025《資料外洩成本報告》：金融服務業每次外洩平均損失 556 萬美元（約新台幣 1.8 億），比全球其他行業平均高 22%。

換算公式：風險損失 = 停機時數 × 每小時營業額 + 客戶流失率 × 客戶終身價值 + 裁罰金額 + 品牌修復成本

🏢 大企業

風險損失 = 停機時數 × 每小時營業額 + 客戶流失率 × 客戶終身價值 + 裁罰金額 + 品牌修復成本

🏠 中小企業

漏洞風險 → 相當於幾個月營業額、客戶合約違約金，最壞情境：公司能不能撐過這一關。

Step 3：綁法規—— 合規壓力，是老闆聽得懂的语言

金管會《金融資安韌性發展藍圖》

2025 年底發布。零信任架構從「鼓勵」升級為 **2026 年必須導入**。

SBOM 軟體供應鏈安全機制

建立軟體物料清單為強制要求，違反業者將受罰。影響範圍不限金融機構，所有第三方 IT 供應商均需跟進。

API / AI / 容器服務新規

2026 年新增資安基準與指引，涵蓋 API 安全、AI 系統安全與容器服務監控，金融機構必須提前準備。

正確說法：「依據金管會今年的要求，我們距離 2026 年標準還差三件事——這是差距清單，這是補齊時程，這是如果不補齊的裁罰風險與說明責任。」

大企業

金管會韌性藍圖 / SBOM / 零信任——說差距清單，不說條文編號。

中小企業

個資法 + 電商平台資安條款 + 客戶合約——「資料外洩須通報，違約條款可能觸發，接政府標案資格可能取消」

Step 4：給選擇——

老闆的工作是做選擇，不是解讀技術報告

技術人最常犯的錯，是只報問題，不給選項。「建議修補」讓老闆說「你去處理」，然後預算沒批、時程沒排，三個月後依然原地。給三個選項，讓老闆真正做一個決定。

✅ 選項 A (建議) 立即修補

- 成本：NT\$20 萬 + 2 週工時
- 效果：消除風險，符合金管會要求
- 代價：需安排系統維護時段

⚠️ 選項 B (折衷) 暫緩 90 天

- 成本：NT\$5 萬/月加強監控
- 效果：降低但無法消除風險
- 代價：事故發生仍承擔全責

🚨 選項 C (警示) 不處理

- 現在成本：NT\$0
- 代價：IBM 2025 金融業平均 556 萬美元
- 另加金管會裁罰 + 品牌損失

「我的建議是選項 A，原因是成本最低、風險最小、合規達標。」

📄 大企業版

三選項卡片，正式報告格式，附 IBM 金融業數據。

📄 中小企業版

只給一個行動——「我需要你這週批 NT\$X 萬，我來搞定」（給三個選項，老闆說「讓我想想」就沒了）

Step 5：說時間軸

90 天不動，會發生什麼？

人類大腦對未來風險的感知很弱，對眼前成本的感知很強。你要讓風險有時間感，讓它從「未來某個時間點的問題」變成「眼前的事」。



❌ IBM 2025 | 近三分之二的受害組織，資料外洩發生後，仍在持續復原中。那個「持續」的代價，才是真正的成本。
風險不會因為沒人處理而消失，它只會在你不注意時爆發。

五步翻譯模型快速回顧

每次進會議室前，用這張圖確認你的報告是否已完成翻譯。



實戰案例 A：翻譯示範

同一個漏洞，兩種說法，兩種結果

Before (工程師語言)

- ❏ 「API 介面存在未授權存取漏洞，攻擊者可繞過身份驗證，CVSS 8.1，建議修補。」

老闆反應：低頭看手機。會議結論：待討論。

After (CEO 決策語言)

- ✅ 「我們的 App 有個後門，任何人不需帳號就能看客戶資料。台灣每天 263 萬次攻擊，這個後門現在是公開目標。修補 NT\$15 萬，兩週完成。不修：金管會裁罰起點 NT\$200 萬。我需要你今天授權。」

老闆反應：抬起頭，問「兩週確定能修完嗎？」→ 當場授權。

同樣的漏洞，同樣的風險，差別只在說話的語言和順序。這就是翻譯的力量。

五步模型的每一步都在這段話裡出現了：受眾（CEO）、金額（NT\$15 萬 vs NT\$200 萬）、法規（金管會）、選擇（修 vs 不修）、時間（今天授權）。



跨部門溝通：不同部門要說不同話

與業務單位溝通

衝突場景：

業務說「這個功能下週要上線，客戶都在等，你們資安每次都在擋事」，

資安說「有漏洞，建議延後上線，這是技術規範要求。」。

翻轉說法：「修補兩週 vs 出事後復原六週，你選哪個？」

共識語言三原則

1. 從業務目標出發，再接資安要求
2. 把風險翻譯成對這個專案的威脅
3. 提供最小影響方案

與技術團隊溝通

常見錯誤：把老闆壓力向下傳
(情緒，不是優先順序)。

正確做法

1. 定義 P0/P1/P2 的業務意義
2. 讓工程師知道脈絡 (CFO 估算損失 NT\$300 萬)
3. 把成果翻譯回決策語言，讓工程師看到貢獻 (告訴工程師：「這次消除了一個 NT\$300 萬的風險，同時讓金管會合規達標進度往前一格。」讓他看到貢獻。)

ISC2 2025：溝通是資安從業人員最需要的非技術能力 (59%)。

大企業

與業務 VP 溝通用「延兩週 vs 賭六週停擺」；與工程師建共識語言，讓他知道業務脈絡。

中小企業

老闆、業務通常是同一批人——重點是讓老闆知道「這件事和他的生意直接相關」。

實戰案例 B：同一份風險，兩場會議，兩種結果

翻轉前

- 1 技術術語堆疊
CVE-2025-3842、CVSS 9.1、API 未授權存取漏洞.....
- 2 CEO 低頭看手機
CFO 問助理今天還有幾場會議
- 3 決議：待討論
下次再跟進，預算未批，時程未排
- 4 時間：90 分鐘
沒有結論，沒有決策，資源浪費

✓ 翻轉後（五步模型）

- 1 定受眾
開場：「我需要就一個影響金額超過 NT\$200 萬的風險，取得修補授權。」
- 2 換單位 + 綁法規
兩個高風險漏洞，潛在損失 NT\$200-400 萬，距金管會截止 60 天
- 3 選擇 + 時間軸
選項 A：今天授權 vs 60 天後違規窗口
CEO：「好，授權，下週三給我進度報告。」
會議時間：20 分鐘。有結論。

90 分鐘沒結論 → 20 分鐘拍板

大企業

五步完整跑完，正式季度報告場景，CEO + CFO 一起在場。

中小企業

三步濃縮版——五分鐘站在老闆辦公室門口說完，比開會更有效。

與管理層溝通：一頁紙原則

結論第一，細節備用

① 現況（一句話）

我們有什麼問題——一句話說清楚，不是段落。如果需要兩句以上才能說清楚，代表還沒想清楚，先去想清楚。

② 風險（數字說話）

幾天內不處理，損失是多少（NT\$）、合規風險是什麼、裁罰金額是多少。讓老闆知道他在決定什麼規模的事。

③ 建議（三個選項 + 推薦）

給三個可行方案，各有成本與代價。標出你推薦哪一個，以及原因是什麼。

④ 需要你（今天做什麼決定）

明確說出：「我需要你在今天會議結束前，決定是否授權選項 A 的修補預算。」這句話說出來，會議才有結果。

「資安報告最有效的條件：與業務策略一致、用平易近人的語言溝通風險、支持董事會的監督職能。」—— EY《Enhancing Cybersecurity Metrics: CISO Strategies》2026

「董事會應像對待財務或營運審查一樣看待資安風險討論：策略暴露是什麼？經濟影響是什麼？與業務目標如何對齊？」—— NACD《2026 Cyber Risk Oversight Handbook》

工具 1：風險翻譯公式卡

帶走這張卡，下次口頭報告就能用。每次寫風險報告之前，把它拿出來填。

漏洞 / 風險名稱

技術描述（原版）：__

受眾：□ CEO □ CFO □ CISO □ 業務主管

翻譯後一句話：__

金額估算

停機 NT\$__ / 裁罰 NT\$__ / 修補 NT\$__

相關法規：□ 金管會韌性藍圖 □ 個資法 □ ISO 27001

選項

選項 A（建議）：__ NT\$__

選項 B（折衷）：__ NT\$__

不處理代價：__

知識詛咒自檢清單

「知識詛咒」來自 1989 年史丹佛研究：當你知道一件事之後，你永遠無法想像不知道它是什麼感覺。

- ☐ 縮寫都解釋了嗎？（CVE、CVSS、RCE）
- ☐ 風險有 NT\$ 單位？
- ☐ 給了三個選項（或一個行動）？
- ☐ 說了時間軸？

 大企業

 中小企業

四個自檢問題全用，搭配正式三選項格式。

縮短為三個問題——有沒有說生存威脅？有沒有給金額？有沒有要一個行動？

工具 2：一頁式資安決策簡報模板

進會議室前確認四件事：時限欄有填？現況是一句話？三選項都有成本？決定欄可以勾選？

給：（決策者）	日期：	時限：__
■ 現況（1 句話） 我們發現__，影響__。	■ 風險（數字說話） 若__天內未處理：損失 NT\$__，合規風險：__	■ 三個選項 A（建議）：__ NT\$__ 時程__ B（折衷）：__ NT\$__ 風險__ C（不動）：代價 NT\$__（IBM 2025：金融業平均 556 萬美元）
■ 我需要你做的決定（今天結束前） ☐ 授權選項 A ☐ 授權選項 B ☐ 安排下次討論（截止：__）		進會議室確認 ☐ 時限欄有填？ ☐ 現況是一句話？ ☐ 三選項有成本？ ☐ 決定欄可勾選？

 大企業

正式書面格式，進會議室前準備，讓對方勾選。

 中小企業

口頭版三步——① 一個問題 ② 損失金額 ③ 「我需要你這週批 NT\$X 萬」（最後一句必說，否則沒有結果）

資安不缺技術， 缺的是能進決策室的語言

2025 年那家金融機構的資安團隊，技術能力沒有問題。他們發現了漏洞，他們寫了報告，他們送出去了。但那份報告，沒有人看得懂它在要求什麼決定。三個月後，數十萬名客戶的資料外洩了。技術沒有問題。語言出了問題。



五步翻譯模型

定受眾 → 換單位 → 綁法規 → 給選擇 → 說時間軸。WEF、EY、NACD 一致推薦方向。



風險翻譯公式卡

每次報告前填一遍，用知識詛咒自檢清單打破技術盲點，確保說的是老闆的語言。



一頁式決策簡報模板

進會議室前準備好，讓對方勾選，會議有結論。明天就能用。

「下次你寫風險報告之前，先問自己——
這份報告，老闆看完之後，知道要做什么決定嗎？」

如果答案是不確定，就把今天的五步走一遍。



DevSecOps Taiwan



Nicky@DevSecOpsAgile

AG3_DevSecOps Taiwan (1500+)



https://bit.ly/AG3_DevSecOps

每月免費線上分享

歡迎加我好友

